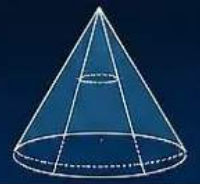


AGENTIC AI GOVERNANCE DRIFT CONE FRAMEWORK™ - V1.0

From Documented Governance to Demonstrable Governance



Governance Drift is an analytical lens for identifying situations in which formally defined governance, authority, controls, accountability, or operating boundaries no longer align with the expected, implemented, or observed state of an AI-enabled environment, including material changes in evidence, assumptions, context, permissions, configurations, decision boundaries, data, tools, or execution conditions.

Governance Drift is used here as an analytical root-cause lens—not as a claim that it is a universally defined regulatory, auditing, or control classification.



THE FOUNDATIONAL DISTINCTION

Documentation ≠ Implementation ≠ Operation ≠ Effectiveness

A policy, procedure, control repository, or governance document can establish what management defines, expects, or authorizes.

It does not, by itself, establish actual execution, operation within the authorized boundary, effectiveness, continuity throughout the relevant period, or absence of unauthorized bypass.

Control existence is not control operation.

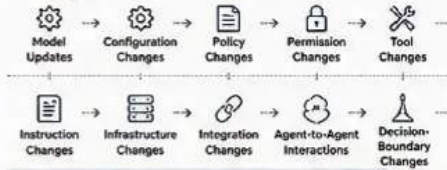
The stronger assurance question is:
Did the control operate as required, by the appropriate authority, within the applicable boundary, during the relevant period?



AUTHORITY IS NOT SELF-VALIDATING

Formal authority establishes an authorized condition. It does not, by itself, establish that subsequent execution remained within that authority or that the control continued to operate effectively throughout the relevant period.

For Agentic AI, this becomes particularly important because the operating environment may change through:



Previously granted authority does not, by itself, prove that subsequent execution remained within the authorized boundary.



THE CRITICAL DISTINCTION

Capability ≠ Recommendation ≠ Approval ≠ Authority ≠ Execution

An AI system may possess the technical capability to perform an action without being authorized to perform it.

Documentation stating that approval is required does not automatically demonstrate that the threshold was enforced, the designated person approved the decision, the approver possessed appropriate authority, the approval related to the actual decision, the agent could not bypass it, or the resulting action remained within the authorized boundary.

THE THREE STATES THAT MUST NOT BE COLLAPSED



EXPECTED STATE

What should exist or operate according to the applicable authority, criteria, and control objective.



IMPLEMENTED STATE

How the control has actually been configured or deployed.



OBSERVED STATE

What reliable evidence demonstrates actually existed or occurred.

Expected State → Implemented State → Observed State

A difference between these states is a signal requiring evaluation—not automatically proof of a control failure.

SIX MANIFESTATIONS OF GOVERNANCE DRIFT

RISK	DRIFT MANIFESTATION
1 SoD / Authority Violation	Authority Drift — the observed execution state moves outside approved decision rights, authorization, segregation, or decision boundaries.
2 No Reliable Audit Trail	Evidence Drift — required evidence is unavailable, incomplete, unreliable, or insufficient to support the defined assurance assertion.
3 Model / Behavioral Drift	Validation Drift — observed behavior or operating conditions differ materially from validated assumptions, expected controls, or approved operating conditions and therefore require evaluation.
4 Governance Gap	Accountability Drift — ownership, authority, escalation, or responsibility is not sufficiently defined or cannot be reliably established for the relevant assertion.
5 Vendor / Data Risk	Boundary Drift — data, permissions, processing, tools, integrations, or dependencies extend beyond the applicable authorized boundary.
6 BCP / Resilience Failure	Resilience Drift — the implemented or observed operating state falls outside applicable continuity, recovery, fallback, or fail-safe requirements.

These are analytical categories, not predetermined audit findings.



CHANGE DOES NOT AUTOMATICALLY EQUAL FAILURE

A detected difference is a signal requiring evaluation. For a material delta, the assurance process should establish:

- What changed?
- When did it change?
- What was authorized?
- What was expected?
- What was observed?
- Was the change authorized?
- Was it appropriately implemented?
- Was it adequately evidenced?
- Did it affect the control objective or risk?
- Was the resulting state within the authorized boundary?
- What conclusion does the evidence support?



No detected change is not automatically proof that no change occurred. The strength of a no-change conclusion depends on the completeness, coverage, reliability, and capability of the detection process.



EVIDENCE MUST BE FIT FOR THE ASSERTION

The fundamental assurance chain is:

Assertion → Criterion → Evidence → Test → Conclusion

Evidence must be evaluated according to the specific assertion being tested.

System-generated or AI-generated evidence is not inherently reliable merely because it came from a system.

Absence of evidence is not automatically evidence of absence.

The conclusion must follow the specific control objective and evidence requirement.



REVOCABILITY MUST BE DEMONSTRABLE

A documented emergency-stop procedure establishes an intended control. It does not automatically prove effective revocation.

The stronger assurance question is:

Can the organization demonstrate that the agent became unable to perform the prohibited action within the required control boundary and time period?

A stop instruction is not, by itself, proof of control.

The objective is to establish whether the required control effect actually occurred.



THE CONTROL-UNIVERSE PRINCIPLE

A comparison is only as strong as its comparison basis.

A control repository does not automatically establish that the universe contains every control relevant to the assurance objective.

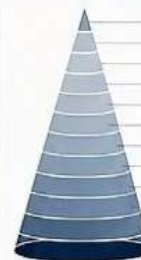
The applicable control universe may include:

- Laws & Regulations
- Policies
- Risk Requirements
- Business Processes
- Technology Architecture
- System Configuration
- Security Requirements
- AI Governance
- Decision Boundaries
- Human Oversight
- Automated Controls
- Technical Guardrails
- Agent Permissions
- Tool Restrictions

Universe Completeness ≠ State Completeness
≠ Evidence Completeness

These dimensions must be assessed separately and connected through the assurance methodology.

THE ASSURANCE ARCHITECTURE



- 1 Assurance Objective
- 2 Scope & Criteria
- 3 Authoritative Control Universe
- 4 Expected Control State
- 5 Implemented State
- 6 Observed Operating State
- 7 Historical / Prior State
- 8 Delta Analysis
- 9 Evidence Validation
- 10 Independent Testing
- 11 Exception & Limitation Assessment
- 12 Assurance Conclusion

This moves governance from documented intent to demonstrable operation.

THE NON-NEGOTIABLE RULES

- ✓ No assertion without a defined criterion.
- ✓ No conclusion without evidence appropriate to the assertion.
- ✓ No evidence accepted without considering its reliability and relevance.
- ✓ No claim of operating effectiveness from design documentation alone.
- ✓ No claim of historical operation from a current snapshot alone.
- ✓ No claim of universe completeness without defining the universe and assurance objective.
- ✓ No delta interpreted as a control failure without appropriate evaluation.
- ✓ No "no delta" conclusion treated as proof that no change occurred without adequate detection coverage.
- ✓ No absence of evidence automatically treated as evidence of absence.



THE GOVERNING PRINCIPLE

AI capability does not create authority. Formal authorization does not, by itself, prove implementation, operation, effectiveness, or continuing conformity with the authorized boundary. Those conclusions must be established through the applicable criteria, defined assurance objective, relevant control universe, expected and observed states, appropriate evidence, relevant period, change analysis, testing, and professional evaluation.

Governance must not merely be documented. It must be demonstrable.



THE ULTIMATE QUESTION IS NOT MERELY: "DO WE HAVE THE CONTROL?"

"Can we independently demonstrate, within the defined scope, criteria, and relevant period, that the relevant control was appropriately defined and authorized, sufficiently represented for the assurance objective, implemented and operated within its intended boundary, supported by sufficient appropriate evidence, and that material changes, exceptions, and limitations were identified and appropriately evaluated?"



That is the transition from documented governance to demonstrable governance.

AGENTIC AI GOVERNANCE DRIFT CONE FRAMEWORK™ - V1.0

Governance Drift is an analytical lens for identifying situations in which formally defined governance, authority, controls, accountability, or operating boundaries no longer align with the **expected, implemented, or observed state** of an AI-enabled environment, including material changes in evidence, assumptions, context, permissions, configurations, decision boundaries, data, tools, or execution conditions.

Governance Drift is used here as an analytical root-cause lens—not as a claim that it is a universally defined regulatory, auditing, or control classification.

The fundamental issue is not simply whether governance was documented.

The stronger question is whether the organization can **demonstrate that the relevant governance and controls were appropriately defined and authorized, represented within the applicable control universe, implemented as intended, operated within their authorized boundary, supported by sufficient appropriate evidence, and that material changes and exceptions were identified and evaluated.**

THE FOUNDATIONAL DISTINCTION

Documentation ≠ Implementation ≠ Operation ≠ Effectiveness

A policy, procedure, control repository, or governance document can establish what management defines, expects, or authorizes.

It does **not**, by itself, establish actual execution, operation within the authorized boundary, effectiveness, continuity throughout the relevant period, or absence of unauthorized bypass.

Therefore:

Control existence is not control operation.

The stronger assurance question is:

Did the control operate as required, by the appropriate authority, within the applicable boundary, during the relevant period?

AUTHORITY IS NOT SELF-VALIDATING

Formal authority establishes an authorized condition.

It does **not**, by itself, establish that subsequent execution remained within that authority or that the control continued to operate effectively throughout the relevant period.

For Agentic AI, this becomes particularly important because the operating environment may change through:

Model Updates → Configuration Changes → Policy Changes → Permission Changes → Tool Changes → Instruction Changes → Infrastructure Changes → Integration Changes → Agent-to-Agent Interactions → Decision-Boundary Changes

Therefore:

Previously granted authority does not, by itself, prove that subsequent execution remained within the authorized boundary.

Whether authority remained appropriate must be evaluated against the **defined assurance objective, applicable criteria, relevant control universe, expected state, implemented state, observed state, evidence, relevant period, changes, exceptions, and risk.**

THE CRITICAL DISTINCTION

**Capability ≠ Recommendation ≠
Approval ≠ Authority ≠ Execution**

An AI system may possess the technical capability to perform an action without being authorized to perform it.

Likewise, documentation stating that approval is required does not automatically demonstrate that the threshold was enforced, the designated person approved the decision, the approver possessed appropriate authority, the approval related to the actual decision, the agent could not bypass it, or the resulting action remained within the authorized boundary.

THE THREE STATES THAT MUST NOT BE COLLAPSED

EXPECTED STATE

What should exist or operate according to the applicable authority, criteria, and control objective.

IMPLEMENTED STATE

How the control has actually been configured or deployed.

OBSERVED STATE

What reliable evidence demonstrates actually existed or occurred.

Therefore:

**Expected State ↔
Implemented State ↔
Observed State**

A difference between these states is a **signal requiring evaluation—not automatically proof of a control failure.**

SIX MANIFESTATIONS OF GOVERNANCE DRIFT

Risk	Drift Manifestation
1. SoD / Authority Violation	Authority Drift — the observed execution state moves outside approved decision rights, authorization, segregation, or decision boundaries. Evidence Drift — required evidence is unavailable, incomplete, unreliable, or insufficient to support the defined assurance assertion.
2. No Reliable Audit Trail	Validation Drift — observed behavior or operating conditions differ materially from validated assumptions, expected controls, or approved operating conditions and therefore require evaluation.
3. Model / Behavioral Drift	

4. Governance Gap

Accountability Drift — ownership, authority, escalation, or responsibility is not sufficiently defined or cannot be reliably established for the relevant assertion.

5. Vendor / Data Risk

Boundary Drift — data, permissions, processing, tools, integrations, or dependencies extend beyond the applicable authorized boundary.

6. BCP / Resilience Failure

Resilience Drift — the implemented or observed operating state falls outside applicable continuity, recovery, fallback, or fail-safe requirements.

These are analytical categories, not predetermined audit findings.

CHANGE DOES NOT AUTOMATICALLY EQUAL FAILURE

A detected difference is a **signal requiring evaluation**.

For a material delta, the assurance process should establish:

**What changed? → When did it change?
→ What was authorized? → What was
expected? → What was observed? →
Was the change authorized? → Was it
appropriately implemented? → Was it
adequately evidenced? → Did it affect
the control objective or risk? → Was the
resulting state within the authorized
boundary? → What conclusion does the
evidence support?**

Equally:

No detected change is not automatically proof that no change occurred.

The strength of a no-change conclusion depends on the completeness, coverage, reliability, and capability of the detection process.

EVIDENCE MUST BE FIT FOR THE ASSERTION

The fundamental assurance chain is:

Assertion → Criterion → Evidence → Test → Conclusion

Evidence must be evaluated according to the specific assertion being tested.

System-generated or AI-generated evidence is not inherently reliable merely because it came from a system.

Its integrity, completeness, accuracy, timestamp reliability, access controls, configuration, retention, alteration risk, lineage, independence, population coverage, and evidence-generating controls may require evaluation.

And:

Absence of evidence is not automatically evidence of absence.

The conclusion must follow the specific control objective and evidence requirement.

REVOCABILITY MUST BE DEMONSTRABLE

A documented emergency-stop procedure establishes an intended control.

It does **not** automatically prove effective revocation.

The stronger assurance question is:

Can the organization demonstrate that the agent became unable to perform the prohibited action within the required control boundary and time period?

Therefore:

A stop instruction is not, by itself, proof of control. The objective is to establish whether the required control effect actually occurred.

THE CONTROL- UNIVERSE PRINCIPLE

A comparison is only as strong as its comparison basis.

A control repository does not automatically establish that the universe contains every control relevant to the assurance objective.

The applicable control universe may include:

Laws & Regulations → Policies → Risk Requirements → Business Processes → Technology Architecture → System Configuration → Security Requirements → AI Governance → Decision Boundaries → Human Oversight → Automated Controls → Technical Guardrails → Agent Permissions → Tool Restrictions

Therefore:

**Universe Completeness $\neq$ State
Completeness $\neq$ Evidence
Completeness**

These dimensions must be assessed separately and connected through the assurance methodology.

THE ASSURANCE ARCHITECTURE

For consequential Agentic AI:

Assurance Objective



Scope & Criteria



Authoritative Control Universe



Expected Control State



Implemented State



Observed Operating State



Historical / Prior State



Delta Analysis



Evidence Validation



Independent Testing



Exception & Limitation Assessment



Assurance Conclusion

This moves governance from
**documented intent to demonstrable
operation.**

THE NON-NEGOTIABLE RULES

No assertion without a defined criterion.

No conclusion without evidence appropriate to the assertion.

No evidence accepted without considering its reliability and relevance.

No claim of operating effectiveness from design documentation alone.

No claim of historical operation from a current snapshot alone.

No claim of universe completeness without defining the universe and assurance objective.

No delta interpreted as a control failure without appropriate evaluation.

No “no delta” conclusion treated as proof that no change occurred without adequate detection coverage.

No absence of evidence automatically treated as evidence of absence.

No system-generated or AI-generated evidence treated as inherently reliable.

No management assertion substituted for independent audit evaluation.

No assurance conclusion stronger than the evidence legitimately supports.

THE GOVERNING PRINCIPLE

AI capability does not create authority. Formal authorization does not, by itself, prove implementation, operation, effectiveness, or continuing conformity with the authorized boundary. Those conclusions must be established through the applicable criteria, defined assurance objective, relevant control universe, expected and observed states, appropriate evidence, relevant period, change analysis, testing, and professional evaluation.

And ultimately:

Governance must not merely be documented. It must be demonstrable.

The ultimate question is not merely: “Do we have the control?”

“Can we independently demonstrate, within the defined scope, criteria, and relevant period, that the relevant control was appropriately defined and authorized, sufficiently represented for the assurance objective, implemented and operated within its intended boundary, supported by sufficient appropriate evidence, and that material changes, exceptions, and limitations were identified and appropriately evaluated?”

That is the transition from documented governance to demonstrable governance.